PANDUAN OPERASIONAL KEAMANAN IT

PANDUAN PENCEGAHAN SERANGAN SIBER: WEBSITE, JARINGAN & APLIKASI

Strategi Proteksi Berlapis (Defense in Depth) & Praktik Terbaik Keamanan Sistem Bisnis v1.0

Prinsip Utama: Tidak ada satu sistem pun yang 100% aman. Pendekatan terbaik adalah *Defense in Depth* (keamanan berlapis), memastikan apabila satu lapisan jebol, lapisan lain tetap melindungi data dan infrastruktur bisnis Anda.

1. Keamanan Website (Website Hardening)

Website adalah wajah utama bisnis yang paling sering mendapat serangan luar seperti Defacement, DDoS, dan SQL Injection.

WAF & Anti-DDoS

Pasang **Web Application Firewall (WAF)** (misal: Cloudflare) untuk menyaring lalu lintas data jahat, serangan bot, serta mitigasi banjir trafik DDoS.

Sertifikat SSL/TLS

Wajibkan penggunaan koneksi terenkripsi **HTTPS**. Matikan protokol SSL tua dan gunakan versi TLS 1.2 atau TLS 1.3 terbaru.

Proteksi Panel Admin

Ubah URL default login admin, batasi akses berdasarkan alamat IP (IP Whitelisting), dan aktifkan MFA pada panel CMS.

2. Keamanan Jaringan & Infrastruktur (Network Security)

Jaringan komputer kantor dan server cloud wajib diisolasi dari akses publik tanpa otorisasi:

- **Segmentasi Jaringan (VLANs):** Pisahkan jaringan Wi-Fi tamu, jaringan operasional karyawan, dan jaringan server database. Gunakan prinsip *Zero Trust Network Access (ZTNA)*.
- **Firewall & IPS/IDS:** Aktifkan Stateful Firewall dan *Intrusion Prevention System (IPS)* untuk mendeteksi serta memblokir pemindaian port berlebihan secara otomatis.
- **Amankan Akses Jarak Jauh (Remote Work):** Matikan port RDP (3389) atau SSH (22) yang terbuka langsung ke internet. Wajibkan penggunaan **VPN Terenkripsi** khusus perusahaan.
- **Manajemen Patch & Firmware:** Lakukan pembaruan firmware router, firewall, dan sistem operasi server secara berkala untuk menutup celah keamanan (*vulnerability*).

3. Keamanan Aplikasi & Kode Program (Application Security)

Area Fokus	Ancaman Risiko	Langkah Pencegahan
Input Validation	SQL Injection (SQLi), Cross-Site Scripting (XSS).	Gunakan *Prepared Statements / ORM* dan sanitasi seluruh input formulir.
Manajemen Sesi	Session Hijacking, Credential Stuffing.	Gunakan token cookie secure & HTTPOnly, atur *session timeout* otomatis.
API Security	Kebocoran data via API publik, Broken Auth.	Terapkan API Key, OAuth2, serta pembatasan jumlah permintaan (*Rate Limiting*).
Dependensi Pihak Ke-3	Celah keamanan pada library/plugin open source.	Gunakan alat pemindai otomatis (*Software Composition Analysis*) seperti Dependabot.

4. Proteksi Data & Kebijakan Akses (Data Protection)

Mencegah kebocoran data sensitif perusahaan maupun data pribadi pengguna:

- **Enkripsi Data (At Rest & In Transit):** Enkripsi seluruh basis data menggunakan algoritma AES-256 dan pastikan pengiriman data menggunakan SSL/TLS.
- **Prinsip Hak Akses Minimal (Least Privilege):** Berikan akses basis data atau server sesuai kebutuhan tugas masing-masing personel. Cabut segera akun mantan karyawan.
- **Strategi Backup Data 3-2-1:** Simpan 3 salinan data pada 2 media penyimpanan berbeda, dengan 1 salinan disimpan di lokasi terisolasi offline (*immutable backup*).

5. Checklist Evaluasi Kesiapan Keamanan (Audit Routine)

Gunakan tabel daftar periksa berikut secara rutin bulanan/triwulanan:

Status	Item Pemeriksaan	Kriteria Kelayakan
[ ]	Authentikasi Multi-Faktor (MFA)	Aktif untuk seluruh akun email kantor, admin web, dan server cloud.
[ ]	Uji Coba Pemulihan Backup	Berhasil melakukan *restore* data dari file backup tanpa ada korupsi berkas.
[ ]	Pemindaian Celah Keamanan	Menjalankan pemindaian kerentanan (*vulnerability scan*) pada web & server.
[ ]	Pembaruan Perangkat Lunak	Seluruh plugin web, OS server, dan antivirus/EDR menggunakan versi terbaru.
[ ]	Simulasi Phishing Karyawan	Edukasi kesadaran siber staf dilakukan minimal satu kali dalam 6 bulan.

6. Protokol Tanggap Darurat Insiden (Incident Response)

1. **Isolasi Sistem:** Putuskan koneksi jaringan server/perangkat yang terindikasi terinfeksi serangan secara instan untuk mencegah penyebaran (*containment*).
2. **Ganti Seluruh Kredensial:** Reset kata sandi admin, API keys, dan token akses di seluruh ekosistem bisnis.
3. **Analisis Log & Forensik:** Periksa log akses server untuk mengetahui pintu masuk serangan dan celah yang digunakan penyerang.
4. **Pemulihan & Penambalan:** Lakukan pemulihan data dari backup bersih dan tutup celah keamanan sebelum membawa sistem kembali ke kondisi *online*.